

INCIDENT RESPONSE TABLETOP EXERCISE

After-Action Report (AAR)

Exercise Name: OPERATION QUIET LEDGER | Exercise Date: 2026-05-28

Tailspin Civic Systems, Inc. | AwardWorks Platform | Prepared by: Chris Morrissey, ISSO

Sample GRC portfolio artifact — fictional company and exercise

1. Exercise Overview

Exercise Name	OPERATION QUIET LEDGER
Exercise Type	Discussion-based tabletop exercise (TTX)
Date and Duration	2026-05-28, 3 hours (13:00–16:00 ET)
Scenario Theme	Compromised agency administrator credential leading to suspected unauthorized access to grant applicant PII
Primary Objective	Validate the organization's ability to meet the one-hour US-CERT and agency ISSO notification requirement, including after-hours escalation
Driving Requirement	SAR finding FIND-006 / POA&M item V-006
Controls Exercised	IR-4 (Incident Handling), IR-6 (Incident Reporting), IR-8 (Incident Response Plan), AC-2, AU-6
Facilitator	ISSO (exercise design and control)
Evaluators	Two independent observers: Security Operations Manager (non-participant) and outside counsel
Classification	Controlled Unclassified Information (CUI)

2. Exercise Objectives

The exercise was designed around four measurable objectives, each with defined success criteria established before execution.

#	Objective	Success Criteria
1	Validate the one-hour external notification timeline	Notification decision made and draft notification prepared within 60 minutes of incident determination
2	Test after-hours escalation to non-technical stakeholders	Legal and Communications reached and engaged within 30 minutes of escalation trigger
3	Exercise the incident severity classification process	Severity assigned within 15 minutes of initial alert, with documented rationale
4	Validate accuracy of the contact roster	All required contacts reachable using only information in the current IR Plan roster

3. Participants

Role	Function in Exercise	Organization
Incident Response Lead	Incident Commander	Tailspin Civic Systems

Security Operations Analyst (on-call)	Initial detection and triage	Tailspin Civic Systems
ISSO	External notification decision and drafting	Tailspin Civic Systems
Director of Platform Engineering	Technical containment decisions	Tailspin Civic Systems
General Counsel	Legal and regulatory guidance	Tailspin Civic Systems
Director of Communications	Customer and public messaging	Tailspin Civic Systems
Agency Liaison (simulated)	Sponsoring agency ISSO role	Played by evaluator
Evaluators (2)	Observation and timing	Internal and outside counsel

4. Scenario Narrative and Injects

The scenario unfolded through five timed injects delivered by the facilitator. Participants were not given advance notice of inject content. The exercise clock began at T+0 with the initial detection alert.

Time	Inject	Content Delivered to Participants
T+0	Initial Alert	SIEM alert fires: an Agency Administrator account for a sponsoring agency tenant authenticated successfully from an unrecognized geographic location outside normal business hours, followed by a bulk export of applicant records.
T+18	Escalating Detail	Audit logs show the same account created a new Agency Administrator account and modified role assignments for two existing users. Approximately 4,200 applicant records were included in the export.
T+35	Stakeholder Pressure	The sponsoring agency's program officer emails asking why she received an unexpected account-creation notification. She requests a response within the hour.
T+52	Complicating Factor	Threat intelligence indicates the source IP is associated with a credential-stuffing campaign targeting government SaaS platforms. It remains unclear whether the agency IdP itself is compromised.
T+75	Media Inquiry	A reporter contacts the general company inbox asking whether Tailspin Civic Systems is 'experiencing a data breach affecting grant applicants.'

5. Timeline of Participant Actions

Times reflect the exercise clock as recorded by the evaluators. Actions are those taken or verbally committed to by participants during the exercise.

Time	Action	Evaluator Note
T+0	Alert received and acknowledged by on-call analyst	Acknowledgment within 4 minutes; met internal expectation
T+9	Analyst escalated to Incident Response Lead	Correct escalation path used
T+22	Severity classified as Sev-1 (confirmed unauthorized access to CUI/PII)	Exceeded the 15-minute objective by 7 minutes; see Finding TTX-01
T+26	Containment decision: account disabled, sessions revoked, tenant export capability suspended	Decisive and correctly sequenced

T+31	ISSO engaged and began external notification assessment	Appropriate
T+38	Attempt to reach General Counsel using IR Plan roster — listed mobile number was outdated	Contact roster defect; see Finding TTX-02
T+47	General Counsel reached through an informal channel (personal knowledge of an alternate number)	Objective 2 met only through undocumented means
T+58	Communications Director engaged	Within tolerance
T+64	Draft US-CERT notification completed; agency ISSO notification drafted	Exceeded the 60-minute objective by 4 minutes; see Finding TTX-01
T+71	Debate on whether agency-side IdP compromise changes notification obligations	Productive; no plan guidance existed to resolve it; see Finding TTX-03
T+83	Media inquiry routed to Communications; holding statement drafted	Handled correctly; pre-approved holding statement was located and used

6. Evaluation Against Objectives

#	Objective	Result	Basis
1	One-hour external notification timeline	Partially Met	Draft notification completed at T+64, four minutes past the requirement
2	After-hours escalation to non-technical stakeholders	Partially Met	Legal reached at T+47, but only via an undocumented alternate contact
3	Incident severity classification within 15 minutes	Not Met	Classification occurred at T+22
4	Contact roster accuracy	Not Met	One of eight roster entries was outdated

7. Strengths Observed

- Technical containment was decisive and correctly sequenced. The team disabled the account, revoked active sessions, and suspended tenant export capability within 26 minutes without waiting for full root-cause understanding — the correct instinct for a Sev-1 involving active data exfiltration.
- Evidence preservation was raised unprompted by the on-call analyst before containment actions were taken, avoiding a common tabletop failure where containment destroys forensic artifacts.
- The pre-approved media holding statement existed, was located quickly, and was used appropriately, keeping the media inject from consuming incident response capacity.
- Participants correctly identified that a compromised agency-side credential does not relieve the CSP of its own notification obligations — an accurate reading of the shared responsibility model.

8. Findings and Corrective Actions

Three findings were identified. Each is assigned an owner and a due date, and will be tracked to closure alongside the POA&M.

TTX-01 — Notification and Classification Timelines Missed

Observation. Severity classification took 22 minutes against a 15-minute objective, and the external notification draft was completed at T+64 against a 60-minute requirement. The delay originated in classification: participants spent time seeking additional confirmation before assigning Sev-1, which pushed every downstream step.

Analysis. The Incident Response Plan defines severity tiers but does not state that classification should be made on available information and revised as facts develop. Participants defaulted to seeking certainty, which is the wrong bias when a regulatory clock is running.

Corrective Action. Revise the IR Plan to direct provisional severity assignment within 10 minutes on available evidence, with explicit authority to downgrade later. Add a pre-drafted US-CERT notification template with fillable fields so drafting time is reduced to minutes.

Owner / Due Date. Incident Response Lead / 2026-06-30

TTX-02 — Outdated Contact Information in IR Plan Roster

Observation. The mobile number listed for General Counsel was outdated. Contact was ultimately made only because a participant personally knew an alternate number — a dependency that would not survive personnel turnover.

Analysis. The contact roster has no verification cadence. It is updated reactively when someone notices an error, which by definition means errors are discovered during incidents.

Corrective Action. Institute a quarterly contact roster verification with a documented test call or message to every listed contact. Add a secondary contact method for every role. Move the roster to a location accessible without VPN, since a network-affecting incident could otherwise render it unreachable.

Owner / Due Date. ISSO / 2026-06-15

TTX-03 — No Guidance for Incidents Originating at the Customer Boundary

Observation. When the scenario introduced ambiguity about whether the agency's identity provider was compromised, participants spent roughly twelve minutes debating notification and coordination obligations with no plan guidance to resolve it.

Analysis. The Incident Response Plan addresses incidents originating within the CSP boundary but is silent on incidents where the initial compromise occurs on the customer side and manifests within the platform. This is a foreseeable and arguably more likely scenario than a direct platform compromise.

Corrective Action. Add a section to the IR Plan covering customer-boundary incidents, defining CSP notification obligations regardless of origin, the process for coordinating with the agency's own incident responders, and the decision criteria for suspending a tenant's access during an active investigation. Cross-reference the Customer Responsibility Matrix (IR-6).

Owner / Due Date. Incident Response Lead, with ISSO and General Counsel review / 2026-07-15

9. Corrective Action Summary

Finding	Corrective Action	Owner	Due Date
---------	-------------------	-------	----------

TTX-01	Provisional severity within 10 minutes; pre-drafted notification template	Incident Response Lead	2026-06-30
TTX-02	Quarterly roster verification; secondary contacts; offline-accessible roster	ISSO	2026-06-15
TTX-03	IR Plan section for customer-boundary incidents	Incident Response Lead	2026-07-15

10. POA&M Disposition

This exercise was conducted to satisfy POA&M item V-006, which arose from SAR finding FIND-006. The exercise was executed as planned and the notification workflow was tested end to end with Legal and Communications participation, satisfying the milestone requirements.

However, the exercise demonstrated that the one-hour notification requirement was not met, which means the underlying deficiency is not yet resolved. The ISSO recommends that V-006 remain open pending completion of the three corrective actions above, with closure requested only after a follow-up exercise demonstrates notification within the required timeline.

This recommendation is deliberate. Closing a POA&M item on the basis that an exercise occurred, rather than on the basis that the exercise succeeded, would misrepresent the organization's posture to the Authorizing Official.

11. Recommended Next Exercise

- Conduct a follow-up notification-focused exercise no later than 2026-09-30 to validate corrective actions, using a different scenario vector to avoid rehearsed responses.
- Include the sponsoring agency's actual ISSO as a participant rather than a simulated role, to validate the real coordination path.
- Introduce an unannounced after-hours start time, since both this exercise and the prior one were conducted during business hours with participants pre-assembled.

12. Distribution and Approval

Recipient	Purpose
System Owner	Awareness and resourcing of corrective actions
ISSO	POA&M maintenance and continuous monitoring reporting
Incident Response Lead	Corrective action ownership
General Counsel	Awareness of legal coordination findings
Sponsoring Agency AO (via ConMon submission)	Evidence of contingency and incident response testing

Approved by: Incident Response Lead and ISSO, 2026-06-04. This report contains exercise artifacts only and does not describe an actual security incident.